

=====

INFORMATION SECURITY & DATA RESIDENCY POLICY

=====

Policy reference : POL-SEC-011
Title : Information Security & Data Residency Policy
Document type : internal-policy
Owner : Northgate Systems Ltd – Security / IT
Status : Approved – current

PURPOSE OF THIS DOCUMENT

Security and hosting-location policy behind contract positions on data residency, access control, customer security schedules, incident timelines and third-party/sub-outsourced services.

RELATED LEGISLATION & STANDARDS

- UK GDPR, Art. 5(1)(f) (integrity & confidentiality)
- Computer Misuse Act 1990, s.1 & s.3
- FCA Handbook SYSC 8 (outsourcing, where customer-regulated)

CONTENTS

1. Scope & Security Governance
2. Data Residency & Hosting Locations
3. Access Control & Least Privilege
4. Customer Security Schedules & Exceptions
5. Incident Response & Notification Timelines
6. Supplier & Sub-Outsourcing Security
7. Security Testing & Authorised Access
8. Data Classification & Handling
9. Personnel Security & Training
10. Business Continuity & Disaster Recovery
11. Exceptions, Review & Document Control

CHAPTER 1. SCOPE & SECURITY GOVERNANCE

Policy scope, ownership and review cycle; relationship to POL-PRIV-001 and the security commitments Northgate is permitted to make in contracts.

This policy sets Northgate Systems Ltd's information security and data-residency standards and governs the security commitments Northgate is permitted to make when negotiating customer and supplier contracts. It applies to all Northgate personnel, contractors and systems, and to any third party that hosts, processes or accesses Northgate or customer data on Northgate's behalf.

This policy sits alongside the Data Protection & Privacy Policy (POL-PRIV-001). Where an issue concerns personal data, POL-PRIV-001 governs the data-protection position and this policy governs the technical and organisational security controls that implement it; the two must be read together, and where they overlap (notably incident notification) they are drafted to be consistent.

Contract owners must apply the Contract Playbook (PLAYBOOK) fallback positions and must not offer a security commitment that exceeds Northgate's actual control set without an approved exception under chapter 11.

Ownership and review

Policy owner : Northgate Systems Ltd - Security / IT
Applies to : All personnel, contractors and sub-outsourced suppliers
Review cycle : Annual, or on material change to the control environment
Sister policies : POL-PRIV-001, POL-FIN-007, POL-HR-003, POL-LGL-002, PLAYBOOK

The Security / IT owner maintains the underlying control descriptions on which contractual representations rely. No commitment on hosting location, access, incident timelines or sub-outsourcing may be given to a counterparty that is not supported by a current, documented control, or by an approved, time-limited exception.

CHAPTER 2. DATA RESIDENCY & HOSTING LOCATIONS

Approved hosting regions and residency commitments: EEA-only or UK-only data-centre restrictions that may be offered (e.g. payroll data UK-only), and EU-hosting commitments used as a governing-law fallback concession.

Northgate hosts production data only in approved regions. The default hosting footprint is within the United Kingdom and the European Economic Area. Northgate will not relocate customer production data outside an approved region without prior notice and, where the contract requires it, prior written consent.

Residency commitments that may be offered

- EEA-only hosting: customer production data restricted to EEA data centres. This is a standard, supportable commitment (as applied for the Ostrava Cloud Hosting engagement, CR-2026-004).
- UK-only hosting: data restricted to UK data centres. Offered where a customer or data type requires it, for example payroll data confirmed UK-only for the Bramley Payroll Services engagement (CR-2025-018).
- EU-hosting commitment as a governing-law concession: where a counterparty presses for a foreign governing law, contract owners may retain England and Wales law and offer an EU-hosting commitment as the trade (as with Calder & Voss, CR-2025-028, and Girard Fils, CR-2026-026).

Residency commitments must name the region, not a specific city or facility, so that Northgate retains operational flexibility between approved data centres. Where personal data is involved, residency is one input to the transfer analysis under POL-PRIV-001 chapter 5; choosing EEA-only or UK-only hosting can remove the need for a transfer mechanism, but does not by itself discharge the data-protection assessment. End-of-contract deletion follows the platform's standard purge cycle (30 days) as reflected across the DPA corpus.

CHAPTER 3. ACCESS CONTROL & LEAST PRIVILEGE

Limits on counterparty and supplier access to Northgate systems and data – e.g. support access confined to ticket data, production-database access refused; authentication and privileged-access standards.

Access to Northgate systems and customer data is granted on a least-privilege,

need-to-know basis. Counterparties, suppliers and support providers receive the narrowest access sufficient for their role, and no standing access to production systems is granted by default.

Access boundaries for third parties

- Support access is confined to support-ticket data. Direct access to the production database is refused (as required for the Novapoint Support Desk BPO engagement, CR-2026-048).
- Where a supplier needs data for testing or development, anonymised or synthetic test data is provided; access to live production data is prohibited (as applied for the Applause QA Collective engagement, CR-2026-025).
- Any access must be individually named, logged and time-bound; shared or generic credentials are not permitted.

Authentication and privileged access

Multi-factor authentication is mandatory for all remote and administrative access. Privileged (administrator) access is restricted to named individuals, granted just-in-time where feasible, logged, and reviewed periodically. Access rights are revoked promptly on role change or departure in line with chapter 9. Unauthorised access to, or modification of, Northgate systems is a criminal matter under the Computer Misuse Act 1990 (s.1 and s.3), and contract terms must preserve that position rather than dilute it.

CHAPTER 4. CUSTOMER SECURITY SCHEDULES & EXCEPTIONS

How to review a customer's security schedule against Northgate's control set, which requirements can be accepted, and how exceptions are documented and approved.

Customers frequently attach their own security schedule to an order form. Contract owners must review each schedule against Northgate's documented control set before accepting it, and must not sign up to a control Northgate cannot evidence.

How to review a schedule

- Map each requirement to an existing Northgate control. Requirements that match or fall below the current control set may be accepted as drafted.
- Flag any requirement that exceeds Northgate's controls, imposes a specific technology, or mandates an uncontrollable timeline (for example sub-48-hour incident notification, which is handled under chapter 5).
- Where a requirement cannot be met, negotiate an equivalent control or record a documented exception.

Exceptions are permitted but must be explicit. A customer security schedule may be accepted subject to named carve-outs, as was done for the Bexley Community Health Trust engagement (CR-2026-021), where the schedule was accepted with two exceptions. Each exception must state the requirement not being met, the compensating control offered, and be approved by the Security / IT owner. Accepted schedules and their exceptions are recorded against the contract file so that the committed control set is auditable.

CHAPTER 5. INCIDENT RESPONSE & NOTIFICATION TIMELINES

Security-incident classification and response; standard contractual breach-notification window of 48 hours (12/24-hour demands to be negotiated up), aligned with POL-PRIV-001 chapter 8.

Northgate operates a defined security-incident response process covering detection, triage, classification, containment, eradication, recovery and post-incident review. Incidents are classified by severity and impact; those involving personal data are escalated in parallel under POL-PRIV-001 chapter 8.

Contractual notification window

The standard contractual notification commitment is to notify the affected counterparty without undue delay and in any event within 48 hours of Northgate confirming a qualifying security incident. This 48-hour position is aligned exactly with POL-PRIV-001 chapter 8 so that Northgate gives a single, consistent commitment across the security and data-protection limbs of a contract.

Counterparties sometimes demand 12-hour or 24-hour notification. Contract owners must resist these and negotiate them up to 48 hours; for example, a 12-hour demand was extended to 48 hours on the Bexley Community Health Trust DPA (CR-2026-032). Where a shorter window is unavoidably required by a regulated customer, it must be escalated as an exception under chapter 11 and cannot be agreed at the desk. Notification runs from confirmation of a qualifying incident, not from first alert, and is without prejudice to any separate regulatory reporting duty under POL-PRIV-001.

CHAPTER 6. SUPPLIER & SUB-OUTSOURCING SECURITY

Security requirements flowed down to suppliers and sub-outsourced services, including notification obligations for sub-outsourcing and requirements for regulated customers (FCA SYSC 8).

Where Northgate sub-outsources any part of a service, the security obligations Northgate owes its customer must flow down to the supplier in substance. A supplier's thin or one-sided security terms are not acceptable where Northgate carries a customer-facing commitment; full obligations must be substituted, consistent with the processor-terms approach in POL-PRIV-001 chapter 3.

Requirements flowed down to suppliers

- Least-privilege access, production-access restrictions and MFA equivalent to chapter 3.
- Data-residency commitments consistent with those Northgate has given the end customer (chapter 2).
- Incident notification to Northgate on a timeline that allows Northgate to meet its own 48-hour customer commitment.
- Advance notification of any further sub-outsourcing, with an objection window of at least 30 days, mirroring the sub-processor position in POL-PRIV-001 chapter 4.

Where the end customer is itself regulated, additional outsourcing controls apply. Contract owners must ensure the arrangement supports the customer's obligations under the FCA Handbook (SYSC 8), including audit and access rights, business-continuity assurances and the customer's ability to oversee the outsourced function. Supplier due diligence and the flowed-down terms are recorded on the contract file.

CHAPTER 7. SECURITY TESTING & AUTHORISED ACCESS

Rules for penetration testing and security assessments: prior written authorisation, tightly-defined scope boundaries (Computer Misuse Act exposure), and designation of findings as Confidential Information.

Security testing against Northgate systems - including penetration testing, vulnerability scanning and red-team activity, whether performed by a customer, a customer's tester or a Northgate-appointed firm - is permitted only under prior written authorisation. Testing without authorisation, or outside the authorised scope, risks criminal liability under the Computer Misuse Act 1990 (s.1 and s.3), and this policy exists in part to keep all parties on the right side of that line.

Authorisation and scope

- Written authorisation must be obtained before any testing begins, naming the tester, the systems in scope and the test window.
- Scope boundaries must be tightly defined; shared infrastructure, third-party services and out-of-scope environments are excluded. Scope and authorisation were tightened on this basis for the Redloch Security penetration-testing SOW (CR-2025-012).
- Findings and reports are designated Confidential Information and may not be disclosed or published without Northgate's consent (also applied on CR-2025-012).

Testers must operate within the authorised window, avoid denial-of-service techniques unless expressly agreed, and report material findings promptly so they can be triaged through the incident process in chapter 5. Remediation is tracked to closure, and re-test authorisation follows the same rules.

CHAPTER 8. DATA CLASSIFICATION & HANDLING

Northgate's classification scheme (public / internal / confidential / restricted), handling and labelling rules per class, and how classification maps to the residency and access commitments in chapters 2-3.

Northgate classifies information into four tiers so that handling, residency and access rules can be applied consistently. Every data set Northgate holds is assigned a classification, and the classification drives the controls that apply to it.

Public	: Approved for release; no handling restriction.
Internal	: Default for internal business data; not for external disclosure.
Confidential	: Sensitive business or customer data; access on need-to-know.
Restricted	: Highest sensitivity, including personal data and regulated data; strict access and residency controls.

Handling rules scale with classification: Confidential and Restricted data must be encrypted in transit and at rest, labelled where practicable, and access-logged. Contractual confidentiality obligations extend to any category of data a customer identifies as sensitive - for example confidentiality was extended to underwriting data for the Harwich Marine Insurance engagement (CR-2025-013), engaging the integrity-and-confidentiality principle in UK GDPR Art. 5(1)(f).

Classification maps directly onto the commitments in chapters 2 and 3: Restricted data attracts the residency restrictions (EEA-only or UK-only) and the tightest access boundaries, including the production-access refusals for support and test providers. When a customer identifies a data type as sensitive, contract owners must confirm its classification so the correct residency and access controls are applied.

CHAPTER 9. PERSONNEL SECURITY & TRAINING

Pre-employment screening, confidentiality undertakings, security training at induction and annual refresh, and leaver/mover access revocation aligned with the access-control standards in chapter 3.

Access to Northgate and customer data depends on the trustworthiness and competence of the people who hold it. This chapter sets the personnel-security baseline that supports the access controls in chapter 3 and coordinates with the HR standards in POL-HR-003.

Screening and undertakings

Personnel are subject to pre-employment screening appropriate to their role, including identity and right-to-work checks and, for roles with access to Restricted data or customer environments, additional background verification. All personnel and contractors sign confidentiality undertakings before being granted access, and those undertakings survive termination of engagement.

Training and access lifecycle

- Security awareness training is mandatory at induction and refreshed annually, with completion tracked.
- Role-specific training is provided to teams handling Restricted data or customer environments, coordinated with the data-protection training in POL-PRIV-001 chapter 12.
- Joiner, mover and leaver processes ensure access is provisioned to least privilege on start, adjusted on role change, and revoked promptly on departure, consistent with chapter 3.

CHAPTER 10. BUSINESS CONTINUITY & DISASTER RECOVERY

Backup, recovery and continuity arrangements underpinning the business-continuity commitments offered in contracts (in place of source-code escrow), including RTO/RPO targets and annual test requirements.

Northgate maintains backup, recovery and continuity arrangements so that services and customer data can be restored following disruption. These arrangements underpin the business-continuity assurances Northgate offers in contracts in place of source-code escrow, which Northgate declines as a matter of policy; a business-continuity commitment is offered instead.

Backup and recovery

- Production data is backed up on a regular schedule, with backups held in an approved region consistent with the residency commitments in chapter 2.
- Recovery Time Objective (RTO) and Recovery Point Objective (RPO) targets are defined per service and are the figures against which contractual continuity commitments are set.

- Backups are encrypted and access to them is controlled to the same standard as production data.

Business-continuity and disaster-recovery plans are documented and tested at least annually, with results recorded and remediation tracked. Where a customer requests continuity assurances, contract owners must reference the tested RTO and RPO targets rather than agreeing bespoke figures, and must route any request that exceeds current capability through the exception process in chapter 11. Source-code escrow requests are declined and met with the business-continuity commitment instead.

CHAPTER 11. EXCEPTIONS, REVIEW & DOCUMENT CONTROL

Risk-acceptance and waiver process for deviations from this policy (Security owner sign-off, time-limited), monitoring and internal audit, annual review cycle and version history.

Deviations from this policy are permitted only through a documented, time-limited exception. Any commitment that exceeds Northgate's control set - a sub-48-hour incident window, an unsupported residency or access requirement, a customer control Northgate cannot evidence - must be recorded as a risk acceptance and approved before it is agreed with a counterparty.

Exception process

- Each exception states the requirement, the risk, any compensating control, and an expiry date.
- Exceptions require Security / IT owner sign-off; those touching personal data also require the approval route in POL-PRIV-001.
- Exceptions are time-limited and reviewed at expiry; they do not become permanent by default.

Monitoring, review and document control

Compliance with this policy is monitored through logging, access reviews and internal audit. This policy is reviewed at least annually, and out of cycle on a material change to the control environment, a significant incident or new regulatory guidance. Version history is maintained by the policy owner; the current version supersedes all previous versions.

SIMULATED PLACEHOLDER POLICY – Northgate Systems Ltd corpus.
Internal governance document; not legal advice.
